Өгөгдлийн сангийн удирдлага:

Өгөгдлийн сангийн аюулгүй байдал

F.ITM237
Мэдээллийн технологийн тэнхим

С.Өлзийбаяр (Ph.D)

Агуулга

01

Өгөгдлийн сангийн удирдлагын системийн аюулгүй байдлын ойлголт

Аюулгүй байдлын үндсэн ойлголт, ач холбогдол, түгээмэл аюулуудыг судална

02

Хэрэглэгчийн баталгаажуулалт ба үүрэг ролууд

Нэвтрэх эрх, баталгаажуулалт, үүрэг хуваарилалтын механизмууд

03

Өгөгдлийн сангийн зөвшөөрөл ба эрхүүд

Эрх олгох, цуцлах, RBAC механизмууд ба практик хэрэглээ

04

Аудит болон нийцэл

Аудитын систем тохируулах, мониторинг хийх, хууль дүрмийн хэрэгжилт

БҮЛЭГ 1

Өгөгдлийн сангийн аюулгүй байдлын ач холбогдол

Өгөгдлийн сангийн аюулгүй байдал нь орчин үеийн байгууллагуудад чухал ач холбогдолтой. Байгууллагуудын үйл ажиллагаа, бизнесийн чухал мэдээлэл нь өгөгдлийн сан дээр тулгуурлан хадгалагддаг учраас өгөгдөл нь тэдний үнэтэй баялаг болдог.

Нууцлал алдагдах

Хувийн мэдээлэл зөвшөөрөлгүй хүмүүсийн гарт орох аюултай. Өгөгдлийн зөрчил нь байгууллагын нэр хүнд, үйлчлүүлэгчдийн итгэлцлийг алдагдуулдаг.

Өгөгдлийн бүрэн бүтэн байдал алдагдах

Өгөгдөл хакердах, өөрчлөх, устгах зэрэг үйлдэл гарч болзошгүй. Мэдээллийн үнэн зөв байдал алдагдвал шийдвэр гаргалтад сөрөг нөлөөлнө.

Үйл ажиллагааны саатал үүсэх

Байгууллагын өгөгдөлд халдлага орж, систем ажиллахгүй болох эрсдэлтэй. Үйлчилгээ тасалдах нь санхүүгийн хохирол учруулна.

Өгөгдлийн сангийн аюулгүй байдлын стратегийн ач холбогдол

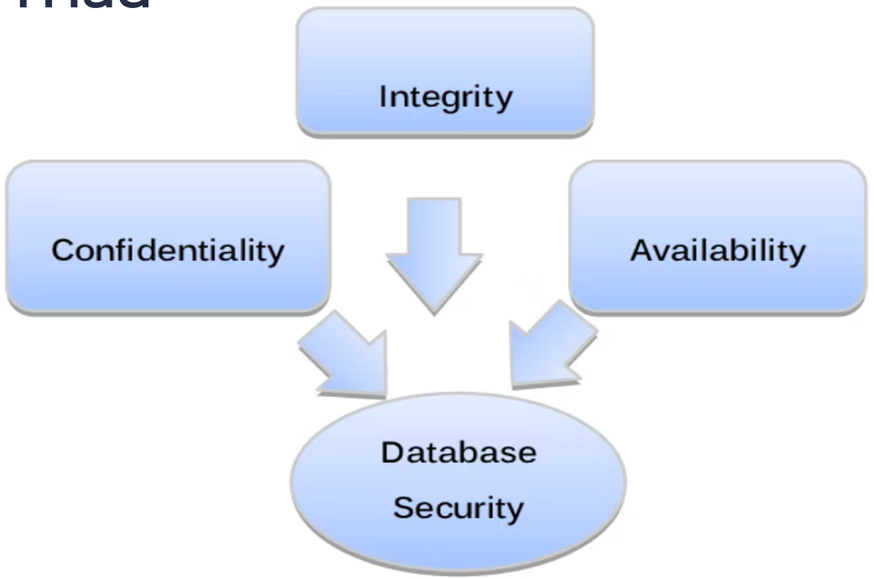
Өгөгдлийн сан бол байгууллагын хамгийн үнэтэй нөөцийн нэг юм. Мэдээллийн нууцлал, бүрэн бүтэн байдал, хүртээмжийг хангахын тулд өгөгдлийн сангийн аюулгүй байдал нь чухал үүрэгтэй.

ӨСАБ-ийн ач холбогдол:

- **Нууц мэдээлэл хамгаалах:** Хувийн мэдээлэл (**PII**), санхүүгийн мэдээлэл, бизнесийн нууц зэрэгт зөвшөөрөлгүй нэвтрэхээс хамгаалах. Мэдээллийн аюулгүй байдал нь өрсөлдөөний давуу талыг хадгална.
- **Байгууллагын нэр хүндийг хамгаалах:** Өгөгдлийн алдагдал нь байгууллагын нэр хүндэд сөргөөр нөлөөлж, хэрэглэгчид болон хамтрагчидтай итгэл алдагдах шалтгаан болдог.
- **Хууль эрх зүйн нийцэл:** GDPR, HIPAA гэх мэт өгөгдлийн хамгааллын хууль, дүрэмд нийцэх нь хууль эрх зүйн үүднээс зайлшгүй шаардлагатай болсон.

Аюулгүй байдлын үндсэн шинж чанарууд: CIA Triad

Өгөгдлийн сангийн аюулгүй байдлын үндсэн шинж чанарууд нь өгөгдлийг зөвшөөрөлгүй нэвтрэлтээс хамгаалж, өгөгдөл алдагдах, эвдэрч гэмтэхээс урьдчилан сэргийлэхэд чиглэгддэг. Эдгээр гурван үндсэн зарчим нь мэдээллийн аюулгүй байдлын стандарт юм.



Нууцлал (Confidentiality)

Мэдээллийг зөвхөн эрх бүхий хэрэглэгчдэд л нэвтрэх боломжтой болгож, зөвшөөрөлгүй хэрэглэгчид хувийн эсвэл эмзэг мэдээллийг хандаж чадахгүй байхыг хангана. Шифрлэлт, хандалтын хяналт зэрэг механизмуудыг ашиглана.

Бүрэн бүтэн байдал (Integrity)

Өгөгдөл үнэн зөв, тогтвортой байхыг хангана. Бүрэн бүтэн байдлыг хангах нь зөвшөөрөлгүй хэрэглэгчид өгөгдлийг өөрчлөхөөс сэргийлж, зөвхөн эрх бүхий хэрэглэгчдээр дамжуулан хүчин төгөлдөр шинэчлэлт хийгдэхийг баталгаажуулна.

Хүртээмж (Availability)

Зөвшөөрөгдсөн хэрэглэгчид өгөгдлийн санд хүссэн үедээ хандах боломжтой байхыг баталгаажуулна. Хүртээмж нь системийн ажиллагааг сааталгүй, тасралтгүй байлгах, өгөгдлийн сан руу халдлагаас сэргийлэхэд чухал үүрэгтэй.

Түгээмэл аюулууд ба халдлагын төрлүүд

SQL Injection

Энэ бол хакерууд SQL командыг өгөгдлийн санд оруулах замаар системд нэвтрэхийг оролддог халдлага юм. Вэб хуудасны оролтыг буруу ашиглан мэдээллийн санд шууд хандах боломжтой болдог.

Дотоодын халдлага

Түнш эсвэл дотоод ажилтнуудын зүгээс өгөгдлийг устгах, хулгайлах нь аюулын томоохон хэсэг. Эрх мэдлээ урвуулан ашиглах нь гадны халдлагаас илүү хохиролтой байж болно.

Өгөгдлийн алдагдал & Зөвшөөрөлгүй нэвтрэлт

Нууц үг, давхар баталгаажуулалт зэрэг аюулгүй байдлын механизмуудыг ашиглахгүй бол гаднын этгээдүүд эсвэл дотоод хүмүүс системд хулгайгаар нэвтрэх эрсдэлтэй. Сул нууц үг нь хамгийн түгээмэл сул тал юм.

SQL Injection: Халдлагын механизм ба хамгаалалт

Халдлагын арга

SQL Injection халдлага нь SQL командуудыг вэбийн оролтоор дамжуулан өгөгдлийн сангийн системд оруулах замаар хэрэглэгчийн мэдээлэлд зөвшөөрөлгүй хандахыг оролддог. Энэ нь дэлхийн хамгийн түгээмэл вэб аюулгүй байдлын сул талуудын нэг юм.

> **Жишээ команд:**
>
> ***SQL командын оролтонд `"OR '1'='1'"` гэх мэт нэвтрэх эрх олгож болохуйц аюултай команд бичиж болно.***
> ***Энэ нь баталгаажуулалтыг алгасаж, бүх мэдээллийг нээлттэй болгодог.***

Хамгаалах аргууд

- **Параметрт суурилсан асуулга (prepared statements) ашиглах:** Энэ нь SQL кодыг өгөгдлөөс тусгаарлаж, халдлагын эрсдлийг бууруулна.
- **Орж ирж буй өгөгдлийг шалгах, баталгаажуулах:** Бүх хэрэглэгчийн оролтыг нягт шалгаж, зөвхөн зөвшөөрөгдсөн формат, утгыг хүлээн авах.
- **Хамгийн бага эрхийн зарчим:** Өгөгдлийн сангийн хэрэглэгчдэд зөвхөн шаардлагатай минимум эрхийг олгох.
- **Алдааны мессежийг хязгаарлах:** Дэлгэрэнгүй алдааны мэдээллийг хэрэглэгчдэд үзүүлэхгүй байх.

Вэб аюулгүй байдлын нэмэлт сул талууд:

Cross-Site Scripting (XSS)

Reflected болон Stored XSS халдлагууд нь хортой скриптийг вэб хуудсанд оруулж, хэрэглэгчийн мэдээллийг хулгайлдаг.

Эмзэг байдлын ашиглалт

Програм хангамжийн засвар хийгдээгүй сул талуудыг ашиглан системд нэвтрэх халдлагууд байнга илэрдэг.

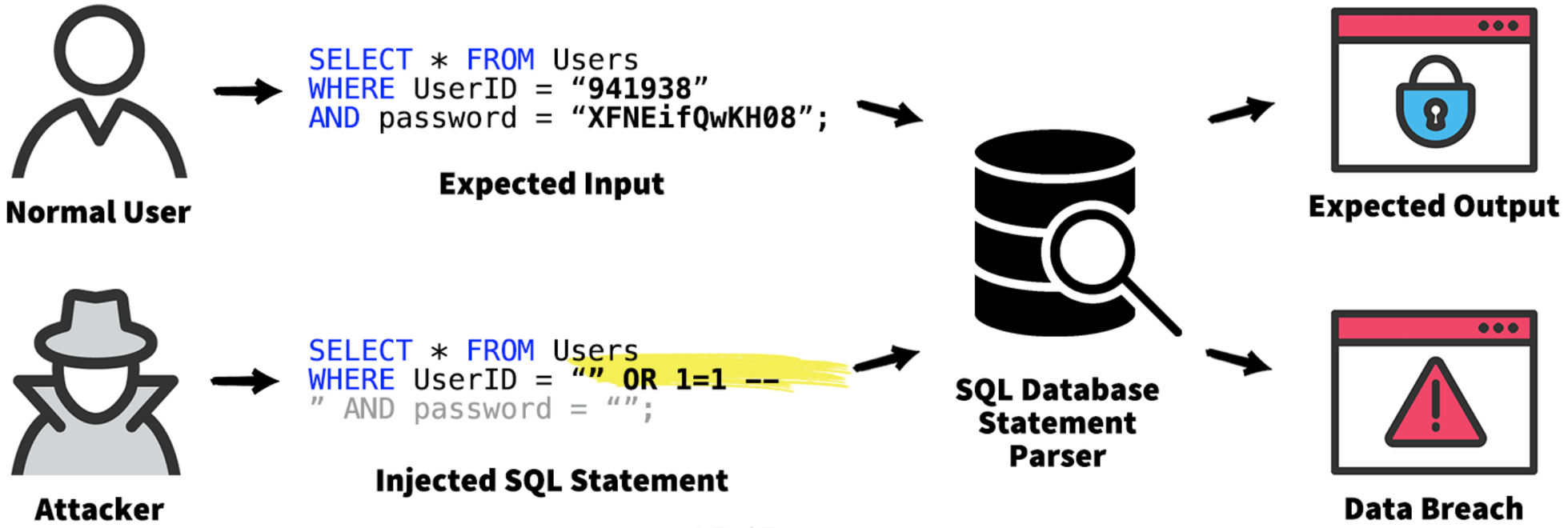
Хамгаалалтын арга хэмжээ

Параметрт статемент ашиглах, засваруудыг байнга суулгах, аюулгүй байдлын тестүүд (penetration testing) тогтмол хийх шаардлагатай.

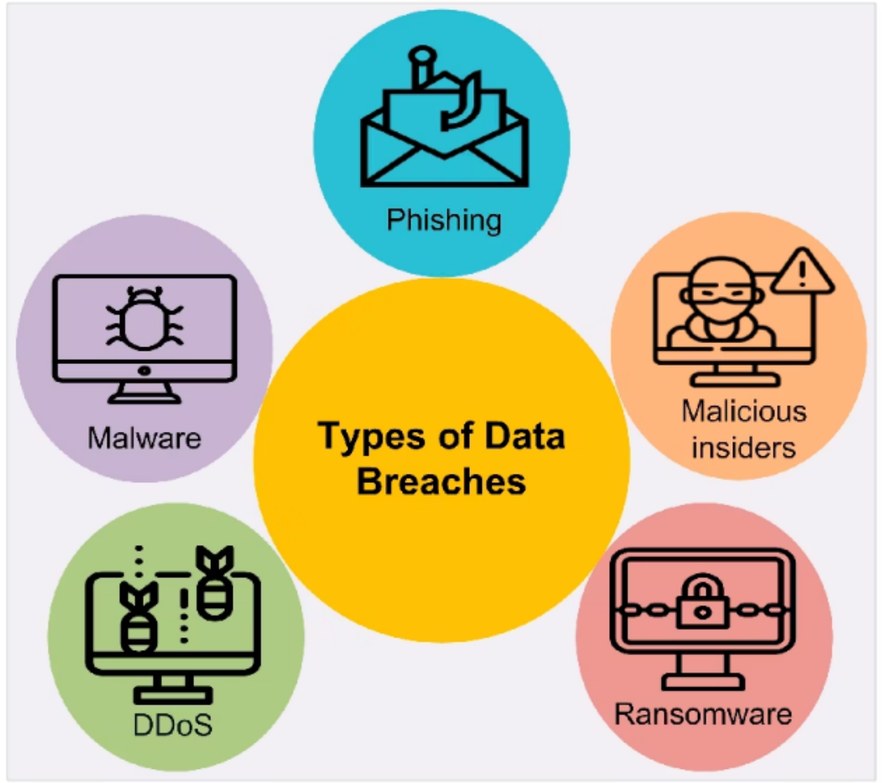
Анхаарах зүйл: *Вэб аюулгүй байдлын OWASP Top 10 жагсаалт нь жил бүр шинэчлэгддэг бөгөөд хамгийн түгээмэл аюулуудыг тодорхойлдог. Өгөгдлийн сангийн администраторууд эдгээр аюулуудтай танилцаж, тэдгээрээс хамгаалах стратеги боловсруулах ёстой.*

Вэб аюулгүй байдлын нэмэлт сул талууд:

Cross-Site Scripting (XSS)



Өгөгдлийн алдагдал: *Эрсдэл ба хамгаалалт*



Data Breaches буюу Өгөгдлийн алдагдал

Өгөгдлийн алдагдал гэдэг нь хакерууд эсвэл зөвшөөрөлгүй хүмүүс өгөгдөлд хандаж, түүнийг хулгайлах, устгах үйл явц юм. Энэ нь байгууллагуудын хувьд хамгийн хохиролтой аюулуудын нэг бөгөөд дараах үр дагавартай:

- *Бизнесийн нэр хүндийг алдагдуулах*
- *Үйл ажиллагааг саатуулах, санхүүгийн алдагдал*
- *Хуулийн хариуцлагад орох, торгууль төлөх*
- *Үйлчлүүлэгчдийн итгэлцэл алдагдах*

Өгөгдлийн шифрлэлт

Өгөгдлийн нууцлалыг хангах үндсэн арга бол өгөгдлийг шифрлэх явдал юм. Хадгалагдаж буй өгөгдөл болон дамжуулагдаж буй өгөгдлийг шифрлэх шаардлагатай.

Хандалтын хяналт

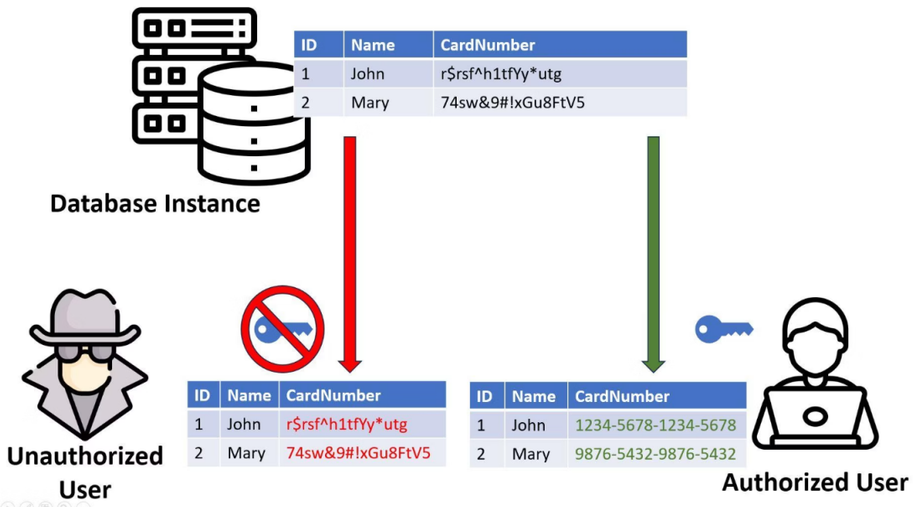
Хандалтын хяналтын механизмыг ашиглах, зөвшөөрөлгүй хандах оролдлогыг илрүүлэх системүүд (Intrusion Detection Systems - IDS) хэрэгжүүлэх.

Нууц үгний шифрлэлт

MD5, SHA256, Bcrypt, Argon2 зэрэг алгоритмуудыг ашиглан нууц үгийг аюулгүй хадгална. Орчин үеийн стандарт нь Bcrypt эсвэл Argon2 ашиглахыг зөвлөж байна.

Нууц үгний шифрлэлтийн алгоритмууд

1. **MD5 (Устарсан):**
   MD5 алгоритм нь ижил hash утга үүсгэж болох хоёр өөр өгөгдлийг үүсгэж чаддаг (collision). Энэ нь аюулгүй байдлын хувьд найдваргүй болсон тул ашиглахыг зөвлөхгүй.
2. **SHA-256:**
   Илүү аюулгүй, 256-бит урттай hash үүсгэдэг нэг чиглэлийн алгоритм. SHA-256 нь илүү бат бөх бөгөөд аюулгүй байдлын шаардлагыг хангаж чаддаг. Блокчейн технологид өргөн ашиглагддаг.
3. **Bcrypt & Argon2:**
   Нууц үгийн шифрлэлтийн илүү бат бөх алгоритмууд бөгөөд MD5-ээс хамаагүй хүчирхэг. Эдгээр нь brute force халдлагад тэсвэртэй, тохируулж болох шифрлэлтийн хурдтай.



Зөвлөмж: *Шинэ системд Argon2-ийг ашиглах нь хамгийн сайн сонголт юм. Хуучин системд SHA-256 ашиглаж байгаа бол аажмаар Bcrypt руу шилжих хэрэгтэй.*

Зөвшөөрөлгүй нэвтрэлтээс хамгаалах

Зөвшөөрөлгүй нэвтрэлтийн төрлүүд

Зөвшөөрөлгүй хүмүүсийн өгөгдлийн санд нэвтрэх оролдлого нь янз бүрийн хэлбэртэй байдаг. Хэрэв хамгаалалтын механизм сул байвал эдгээр хүмүүс байгууллагын өгөгдөлд хандах боломжтой болно.

Түгээмэл аргууд:

- Хуучирсан, сул нууц үг таах
- Brute force халдлага ашиглах
- Хамгаалалтгүй хэрэглэгчийн дансыг ашиглах
- Social engineering аргаар мэдээлэл олох

Хамгаалалтын механизмууд

- **Нууц үгийн бодлого:** Зохистой урт (12+ тэмдэгт), нарийн төвөгтэй нууц үг шаардах. Том, жижиг үсэг, тоо, тэмдэгт хослуулах.
- **Давхар баталгаажуулалт (2FA):** Хоёр давхар баталгаажуулалт ашиглан нэвтрэлтийн аюулгүй байдлыг эрс нэмэгдүүлнэ.
- **IP хязгаарлалт:** IP хаягаар нэвтрэхийг хязгаарлах, зөвхөн тодорхой сүлжээний хэрэглэгчдийг нэвтрэх боломжтой болгох.
- **Нэвтрэлтийн оролдлогын хяналт:** Дахин дахин буруу оролдлого хийвэл түр хориглох систем.

Дотоодын аюул: Insider Threats

Дотоодын аюулын тодорхойлолт

Дотоодын аюул гэдэг нь байгууллагын доторх хүмүүс (ажилчид, гэрээт ажилтнууд, түншүүд) эрх мэдлээ ашиглан өгөгдлийн сан руу халдах үйлдлийг хэлнэ. Эдгээр хүмүүс байгууллагын нууц мэдээлэлд шууд хандах эрхтэй тул, тэдний хяналтгүй үйлдэл нь томоохон аюулд хүргэж болно.

Түгээмэл жишээнүүд

Ажилтан нууц өгөгдөл хулгайлах, санаатайгаар эсвэл санамсаргүйгээр өгөгдөл устгах, хуурамч мэдээлэл оруулах, эрх мэдлээ урвуулан ашиглах зэрэг. Зарим тохиолдолд өрсөлдөгч компанид мэдээлэл зарах явдал ч гардаг.

Хамгаалалтын стратеги

Хэрэглэгчийн хандалтыг байнга хянах, ажилтнуудын хандах эрхийг хязгаарлах (***least privilege principle***), аудитыг байнга явуулах, эмзэг өгөгдөлд хандах үйлдлийг лог хөтлөх. Ажилтнуудыг аюулгүй байдлын сургалтад хамруулах нь чухал.

БҮЛЭГ 2

Хэрэглэгчийн баталгаажуулалт ба үүрэг ролууд

Хэрэглэгчийн баталгаажуулалт болон үүргүүд нь системийн аюулгүй байдлыг сайжруулах, хандах эрхийг удирдах, зөвшөөрөлгүй хандалтаас хамгаалах үндсэн механизм юм. Аюулгүй өгөгдлийн сангийн орчныг бүрдүүлэхийн тулд эдгээр хоёр ойлголтыг зөв ойлгох шаардлагатай.

Хоёр үндсэн бүрэлдэхүүн хэсэг:

- **Хэрэглэгчийн баталгаажуулалт:** Системд хандсан хэрэглэгчийн үнэн зөв, итгэлтэй байдлыг шалгах үйл явц. Хэн байгааг тодорхойлох процесс.
- **Үүргүүд:** Хэрэглэгчдийн эрхийг бүлэглэж, хандах эрхийг удирдах механизм. Юу хийх эрхтэй болохыг тодорхойлно.

Баталгаажуулалтын хэрэгжүүлэлт

Хэрэглэгч үүсгэх

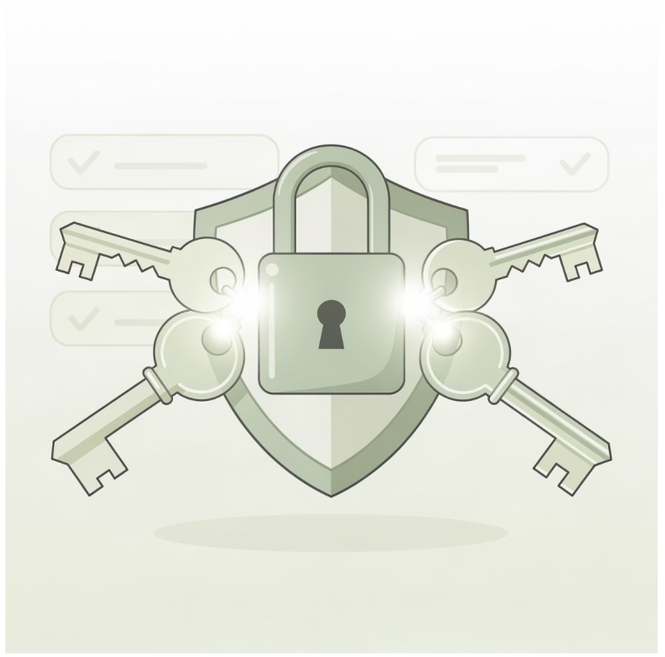
Өгөгдлийн сангийн системд хэрэглэгчийн данс үүсгэх нь анхны алхам юм. Хэрэглэгч бүрт тодорхой эрх, үүрэг оноож өгч, тэдний хандах хүрээг тодорхойлно. Хэрэглэгчийн нэр сонголт чухал.

Нууц үг удирдах

Хэрэглэгчийн данс хамгаалах хамгийн эхний алхам бол нууц үгний бодлого тодорхойлох, хүчтэй нууц үг шаардлага тогтоох явдал юм. Нууц үгийг тогтмол солих, давтагдахгүй байх ёстой.

Нэвтрэлтийн баталгаажуулалт

Нууц үг болон давхар баталгаажуулалт (2FA)-ыг хэрэгжүүлэх нь аюулгүй байдлыг нэмэгдүүлдэг. Биометрик баталгаажуулалт, токен ашиглах нь илүү найдвартай.



Логин ба Хэрэглэгч: Ялгаа ойлгох

SQL Server-д "**логин**" болон "**хэрэглэгч**" нь хоёр өөр ойлголт боловч холбоотой байдаг. Эдгээрийн ялгааг ойлгох нь өгөгдлийн сангийн аюулгүй байдлыг зөв удирдахад чухал.

Логин (Login) - Серверийн түвшин

Тайлбар: Логин нь хэрэглэгчийг SQL Server-ийн экземплярт холбогдох боломжийг олгодог данс юм. Энэ нь хаалгын түлхүүр гэж төсөөлж болно.

Хүрээ: Логин нь серверийн түвшинд байдаг. Энэ нь SQL Server-д хандах эрхийг хянаж, тусгай өгөгдлийн санд хандах эрхийг хянахгүй.

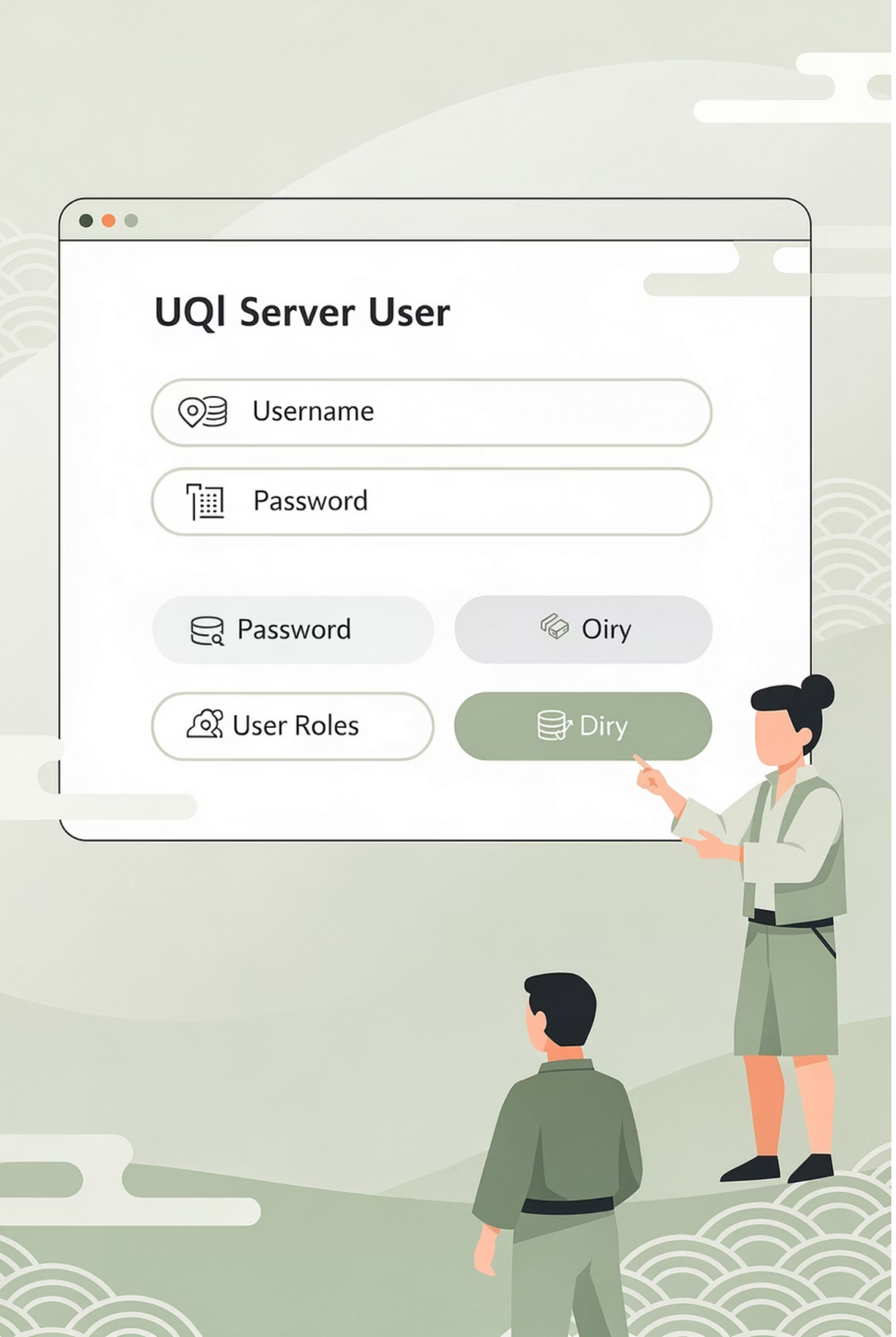
Төрлүүд: SQL Server логин (хэрэглэгчийн нэр болон нууц үг ашигладаг) болон Windows логин (Windows баталгаажуулалтыг ашигладаг) гэсэн хоёр төрөл байдаг.

Хэрэглэгч (User) - Өгөгдлийн сангийн түвшин

Тайлбар: Хэрэглэгч нь SQL Server-ийн тодорхой өгөгдлийн санд хандах боломжийг олгодог данс юм. Энэ нь тодорхой өрөөний түлхүүр гэж төсөөлж болно.

Хүрээ: Хэрэглэгч нь өгөгдлийн сангийн түвшинд байдаг бөгөөд логинтой холбогддог. Нэг логин нь олон өгөгдлийн санд хэрэглэгчидтэй холбогдож болох юм.

Эрх: Хэрэглэгч нь тухайн өгөгдлийн санд хандах тодорхой эрхүүдтэй бөгөөд үүргүүдээр удирддаг.



Логин ба Хэрэглэгч үүсгэх: *Практик жишээ*

Логин болон хэрэглэгч үүсгэх нь өгөгдлийн сангийн администраторын үндсэн ур чадвар юм. Дараах алхмуудыг дагаж гүйцэтгэнэ:

1

Алхам 1: Логин үүсгэх

SQL Server дээр серверийн түвшний нэвтрэх эрх үүсгэнэ. Энэ нь серверт холбогдох боломжийг олгоно.

2

Алхам 2: Хэрэглэгч үүсгэх

Тодорхой өгөгдлийн сантай холбоотой хэрэглэгч үүсгэж, логинтой холбоно.

```
-- 1. Логин үүсгэх
CREATE LOGIN new_user WITH PASSWORD = 'password123';

-- 2. Өгөгдлийн сантай холбоотой хэрэглэгч үүсгэх
USE TestDatabase;
CREATE USER new_user FOR LOGIN new_user;
```

Анхааруулга: *Жишээн дээрх 'password123' нь маш сул нууц үг бөгөөд зөвхөн жишээ болгон үзүүлсэн. Бодит орчинд урт, нарийн төвөгтэй нууц үг ашиглах шаардлагатай. Нууц үгийг кодонд шууд бичихээс зайлсхийх хэрэгтэй.*

Үүргүүд тодорхойлох ба олгох

Хэрэглэгчдэд тодорхой эрхийг олгох нь өгөгдлийн сангийн удирдлагад чухал үүрэгтэй. Үүргүүд нь хэрэглэгчдийн хандах эрхийг хялбар удирдаж, тодорхой бүлэг хэрэглэгчдэд хэрэгтэй эрхүүдийг нэг дор олгоход ашиглагддаг.

Түгээмэл үүргүүд (Common Roles)

- **public:** Бүх хэрэглэгчид хамаарах анхдагч үүрэг. Үндсэн эрхүүдийг агуулна.
- **sysadmin:** Системийн бүхэлд нь бүрэн хяналт тавих хамгийн өргөн эрх. Маш анхааралтай олгох хэрэгтэй.
- **db_datareader:** Хэрэглэгчид бүх хүснэгт болон үзэлтийн өгөгдлийг унших эрх өгдөг.
- **db_datawriter:** Хэрэглэгчид өгөгдөл оруулах болон засах эрх өгдөг.
- **db_owner:** Бүх эрхийг олгодог үүрэг бөгөөд өгөгдлийн сан дээрх бүх үйлдлийг хийх боломжтой.

Үүрэг олгох зарчим

Хэрэглэгчдэд өөр өөр эрх олгох нь зөвшөөрөлгүй нэвтрэлтээс хамгаалах үндсэн механизм юм. Хамгийн бага эрхийн зарчмыг дагаж ажиллах нь чухал.

- Админ эрхтэй хэрэглэгчид бүх өгөгдөлд хандах боломжтой
- Ердийн хэрэглэгчид хязгаарлагдмал эрхтэй
- Уншигч хэрэглэгчид зөвхөн унших эрхтэй

Роль үүсгэх: *SQL команд жишээ*

Өгөгдлийн сангийн системд ролуудыг үүсгэн, хэрэглэгчдэд тодорхой үүрэг хариуцлага хуваарилах нь аюулгүй байдлыг нэмэгдүүлдэг. Дараах жишээ нь хөгжүүлэгчдийн үүргийг хэрхэн үүсгэж, эрх олгохыг харуулж байна.

> **Жишээ сценари:**
> DBA (Database Administrator) нь бүх мэдээлэлд хандах эрхтэй бол, хөгжүүлэгч зөвхөн тестийн орчинд хандах эрхтэй байж болно. Энэ нь production орчны аюулгүй байдлыг хангана.

```
-- Хөгжүүлэгчийн үүрэг үүсгэх
CREATE ROLE 'developer';
-- Үүрэгт зөвхөн SELECT, INSERT, UPDATE эрх олгох
GRANT SELECT, INSERT, UPDATE ON my_database TO developer;
```

Энэхүү команд нь хөгжүүлэгчид зөвхөн тодорхой төрлийн үйлдлийг хийх эрх олгож байна. DELETE эрх олгоогүй нь анхаарах зүйл - энэ нь өгөгдөл санамсаргүйгээр устахаас сэргийлнэ.

> ***Сайн практик:*** *Үүрэг үүсгэхдээ бизнесийн хэрэгцээнд тулгуурлан эрхүүдийг нарийвчлан тодорхойлох хэрэгтэй. Илүү эрх олгохоос илүү бага эрх олгоод дараа нь нэмэх нь илүү аюулгүй.*

Хэрэглэгчийг үүрэгт хуваарилах ба цуцлах

Үүрэгт нэмэх

Хэрэглэгчдийг үүрэгт хуваарилснаар тэдэнд үүрэгт олгосон бүх эрхүүд автоматаар олгогдоно. Энэ нь эрх удирдлагыг хялбарчилдаг.

```
ALTER ROLE manager_role
ADD MEMBER new_user;
```

Энэ команд нь `new_user` хэрэглэгчийг `manager_role` үүрэгт нэмж байна. Одоо `new_user` хэрэглэгчид `manager_role` үүрэгт олгосон бүх эрхүүдийг ашиглах боломжтой болно.

Үүргээс хасах

Хэрэв хэрэглэгчид тодорхой үүргийг цуцлахыг хүсвэл дараах команд ашиглана. Энэ нь ажилтан албан тушаал солих эсвэл чөлөөлөгдөх үед чухал.

```
ALTER ROLE manager_role
DROP MEMBER new_user;
```

Энэ команд нь `new_user` хэрэглэгчийг `manager_role` үүргээс хасах бөгөөд үүргийн эрхүүдийг ашиглах боломжгүй болно.

> ***Анхаарах зүйл:*** *Хэрэглэгчийн үүргийг өөрчлөхдөө тухайн хэрэгцээгээр нь бусад үүргүүдэд хамаарч байгаа эсэхийг шалгах хэрэгтэй. Нэг хэрэглэгч олон үүрэгт хамаарч болно.*

БҮЛЭГ 3

Өгөгдлийн сангийн зөвшөөрөл ба эрхүүд

Өгөгдлийн сангийн системд хэрэглэгч бүрт тодорхой эрхийг олгох нь аюулгүй байдлын үндсэн хэсэг юм. Эрхүүдийг зөв зохистой олгохгүй бол системд халдах боломж нэмэгдэнэ.
Гурван үндсэн команд байдаг: GRANT, REVOKE, DENY.

GRANT - Эрх олгох

Хэрэглэгч эсвэл үүрэгт тодорхой эрхүүдийг олгоход ашиглана. Энэ нь хэрэглэгчид тодорхой үйлдлүүдийг гүйцэтгэх боломжийг олгоно.

```
GRANT SELECT, INSERT
ON my_database
TO 'new_user';
```

REVOKE - Эрх цуцлах

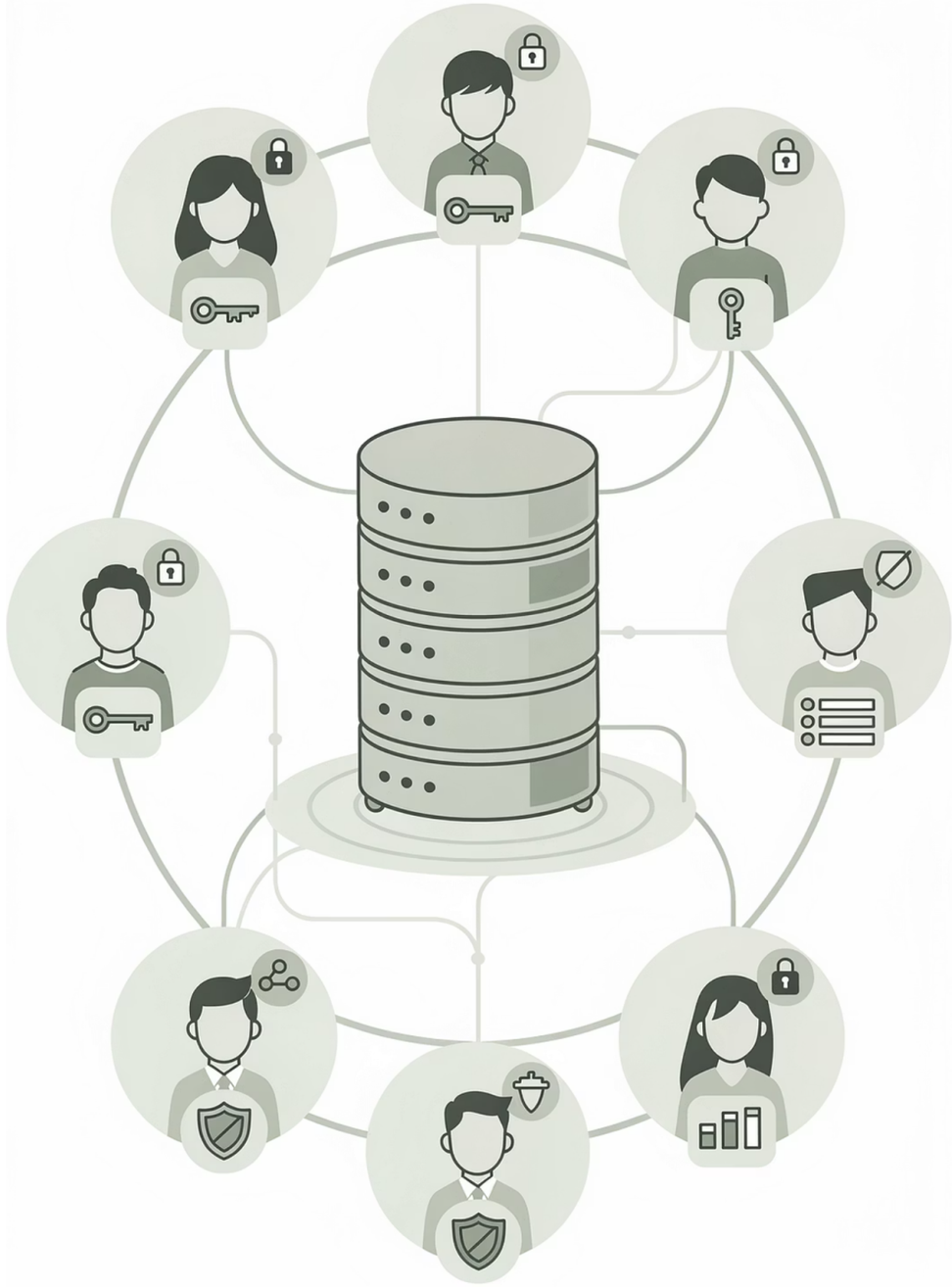
Хэрэглэгчид олгосон тодорхой эрхийг цуцалж буцаах боловч, энэ нь DENY шиг хориг тавихгүй. Хэрэглэгч дахин эрх авч болно.

```
REVOKE INSERT
ON my_database.*
FROM 'new_user';
```

DENY - Эрх хориглох

Хэрэглэгчид тодорхой үйлдэл хийх эрхийг шууд хориглоно. GRANT-г бүрмөсөн хүчингүй болгодог хамгийн хүчтэй хориг.

```
DENY SELECT
ON my_database.*
FROM 'new_user';
```



REVOKE ба DENY: *Ялгаа ойлгох*

REVOKE - Эрх буцааж авах

REVOKE команд нь хэрэглэгчид өмнө нь олгосон эрхийг цуцалж, анхны байдалд буцаана. Энэ нь тухайн үйлдлийг хориглоогүй, зүгээр л зөвшөөрлийг хассан гэсэн үг.

- Хэрэглэгч дахин эрх авч болно
- Өөр үүргээр дамжуулан эрх авч болно
- Зөөлөн хандлага

DENY - Эрх бүрмөсөн хориглох

DENY команд нь хамгийн хүчтэй хориг үйлдэл юм. GRANT-г бүрмөсөн хүчингүй болгоно. Энэ нь тодорхой үйлдлийг хэзээ ч хийхийг зөвшөөрөхгүй гэсэн үг.

- Бусад эрхүүд байсан ч энэ нь давамгайлна
- Хэрэглэгч өөр замаар эрх авч чадахгүй
- Хатуу хандлага

GRANT олгосон

Хэрэглэгч эрхтэй болно

1

DENY хийсэн

Эрх бүрмөсөн хориглогдоно, дахин авах боломжгүй

3

2

REVOKE хийсэн

Эрх цуцлагдана, гэхдээ дахин авч болно

> ***Чухал:*** *DENY нь GRANT-аас илүү хүчтэй. Хэрэв хэрэглэгчид нэг үүргээр GRANT олгосон боловч өөр үүргээр DENY олгосон бол DENY нь давамгайлна.*

Бүрэн жишээ: *Үүрэг үүсгэж хэрэглэгч нэмэх*

Дараах жишээ нь үүрэг үүсгэхээс эхлээд хэрэглэгчид эрх олгох хүртэлх бүрэн процессыг харуулж байна. Энэ нь практикт хэрэглэгддэг бодит сценари юм.

```
-- Алхам 1: Шинэ үүрэг үүсгэх
CREATE ROLE developer;

-- Алхам 2: Үүрэгт SELECT болон INSERT эрхийг олгох
GRANT SELECT, INSERT ON my_database TO developer;

-- Алхам 3: Логин үүсгэх
CREATE LOGIN new_user WITH PASSWORD = 'SecureP@ssw0rd!2024';

-- Алхам 4: Өгөгдлийн сантай холбоотой хэрэглэгч үүсгэх
USE my_database;
CREATE USER new_user FOR LOGIN new_user;

-- Алхам 5: Хэрэглэгчийг үүрэгт нэмэх
ALTER ROLE developer ADD MEMBER new_user;
```

- ***Үр дүн:*** *Одоо `new_user` нэртэй хэрэглэгч `my_database` өгөгдлийн санд хандаж, зөвхөн өгөгдөл унших (SELECT) болон шинэ өгөгдөл оруулах (INSERT) боломжтой болно. Өгөгдөл засах (UPDATE) эсвэл устгах (DELETE) эрхгүй.*

RBAC: *Role-Based Access Control*

RBAC буюу "*Үүргийн үндсэн дээр хандах хяналт*" нь системийн аюулгүй байдлыг хангах, хандах эрхийг удирдах аргачлал юм. Энэ аргачлал нь хэрэглэгчдийн эрхийг хязгаарлахад зориулсан олон улсын стандарт болсон.

Хэрэглэгчид

Хэрэглэгчид тухайн үүрэгт гишүүнчлэлтэй байж, түүний агуулж буй эрхийг авах боломжтой. Жишээ нь, "developer" үүрэгт гишүүн болох хэрэглэгчид өгөгдлийг уншиж, бичиж болох эрхтэй.

Үүргүүд

Хэрэглэгчдийн эрхийг группчилж, нийтлэг зөвшөөрлийг багтаасан үүргүүдийг тодорхойлдог. Жишээ нь, "өгөгдлийн уншигч" (data reader) үүрэг нь зөвхөн өгөгдлийг унших эрхийг агуулна.

Эрхүүд

Үүргүүдийг байгуулж, хэрэглэгчдэд зөвшөөрлийг олгож, хязгаарлахад ашиглагддаг. Эрх нь өгөгдлийн сангийн объект (хүснэгт, үзүүлэлт)-д хандах тодорхой үйлдлүүдийг агуулна.

3

Үндсэн бүрэлдэхүүн

Хэрэглэгч, Үүрэг, Эрх

70%

Удирдлагын хялбарчлал

Эрх удирдлага

5x

Аюулгүй байдал

Илүү сайн хяналт

БҮЛЭГ 4

Аудитын механизмууд тохируулах

Аудитын механизмуудыг тохируулах нь өгөгдлийн аюулгүй байдал, хяналт, нийцлийг хангахад чухал үүрэгтэй. Энэ нь системд хийгдсэн өөрчлөлтүүд, хэрэглэгчдийн хандах үйлдлийг дэмжих зорилготой.

Аудитын зорилго

- **Өөрчлөлт мөшгөх:** Өгөгдлийн сангийн обьектод (хүснэгт, үзүүлэлт) хийгдсэн өөрчлөлтүүдийг шалгах. Хэн, хэзээ, юу өөрчилснийг бүртгэнэ.
- **Хандалт мөшгөх:** Хэрэглэгчид системд хэрхэн хандаж, ямар үйлдлүүдийг гүйцэтгэж байгааг хянах. Сэжигтэй үйлдлийг илрүүлнэ.
- **Нийцэл хангах:** Хууль дүрмийн шаардлагад нийцэж байгааг батлах баримт бичиг бүрдүүлэх.

Аудитын төрлүүд

Дотоод аудит

Системийн дотоод үйлдлүүдийг хянаж, хариуцлагатай шийдвэр гаргахад туслах. Байнгын мониторинг.

Гадаад аудит

Гадаад байгууллага, мэргэжилтнүүдийн хийсэн аудит. Тогтмол хугацаанд хийгддэг.

Аудитын систем хэрэгжүүлэх

Аудитын систем нь өгөгдлийн сангийн үйл ажиллагааг хянах, өөрчлөлт, үйл явцыг бүртгэх боломж олгодог. Энэ нь буруу үйлдлийг хурдан илрүүлэх, хяналт тавихад чухал үүрэгтэй.

Аудитын ашиг тус

Аудит нь өгөгдлийн өөрчлөлт, нэвтрэлтийн түүхийг хадгалж, буруу үйлдэл гарсан тохиолдолд түүнийг мөрдөх боломж олгодог. Цаг хугацааны дагуу юу болсныг нарийвчлан харах боломжтой.

Хэрэгжүүлэх жишээ

Өгөгдлийн санд ямар ч оруулсан өгөгдлийг бүртгэж, хянах боломж олгоно. Энэ нь зөрчлийг илрүүлэхэд тусална.

```
-- Хүснэгт дээрх оруулах үйлдлийг аудитлах
AUDIT INSERT ON my_table;
```

> ***Анхаарах:*** *Аудитлах үйлдлүүдийг нарийвчлан сонгох хэрэгтэй. Хэт их үйлдлийг аудитлах нь системийн ажиллагааг удаашруулж болзошгүй. Зөвхөн чухал өгөгдөл, эмзэг үйлдлүүдийг аудитлах нь зүйтэй.*

SQL Server аудит тохируулах: *Алхам алхмаар*

SQL Server дээр аудит тохируулах нь дараах алхмуудыг дагаж гүйцэтгэнэ. Энэ үйл явц нь тухайн өгөгдлийн санд хийгдсэн өөрчлөлт, үйлдлүүдийг хянаж, логт бүртгэх боломжийг олгоно.

01

Серверийн аудит үүсгэх

Аудитын логийг хаана хадгалахыг тодорхойлно. Файл системд эсвэл Windows Application логт хадгална.

02

Өгөгдлийн сангийн спецификаци үүсгэх

Тухайн өгөгдлийн санд аудитлах үйлдлүүдийг тодорхойлно *(жишээ нь: INSERT, UPDATE, DELETE, SELECT).*

03

Аудитыг идэвхжүүлэх

Аудитыг эхлүүлж, үйлдлүүдийг хянах горимд оруулна. Энэ үеэс эхлэн бүх тохируулсан үйлдлүүд бүртгэгдэнэ.

04

Аудитын логуудыг харах

Аудитын лог мэдээллийг хянаж, шинжлэх. Сэжигтэй үйлдлүүдийг илрүүлж, зохих арга хэмжээ авах.

Аудит тохируулах: *SQL командууд*

1. Аудитын обьект бий болгох

```
CREATE SERVER AUDIT MyAudit
TO FILE (FILEPATH = 'C:\AuditLogs\')
WITH (ON_FAILURE = CONTINUE);
```

2. Аудитын спецификаци тохируулах

```
CREATE DATABASE AUDIT SPECIFICATION MyDatabaseAuditSpec
FOR SERVER AUDIT MyAudit
ADD (UPDATE, DELETE ON dbo.MyTable BY [public]);
```

3. Аудитыг идэвхжүүлэх

```
ALTER SERVER AUDIT MyAudit WITH (STATE = ON);
```

Аудитын мэдээллийг хадгалах

Аудитын мэдээллийг лог файлд хадгалж, хяналт шалгалтанд ашиглах. Файлуудыг архивлаж, урт хугацаагаар хадгална.

Хэрэглэгчийн хандалтыг мөшгөх

Хэрэглэгчийн нэвтрэх, үйлдлүүдийг хадгалах. Хэрэглэгчдийн үйлдлүүдийн журналуудыг байнга шалгах.

Аудитын логуудыг шинжлэх

Аудитын лог мэдээллийг үр дүнтэй шинжлэх нь аюулгүй байдлын түвшинг хадгалахад чухал.

Дараах аргуудаар логуудыг хянаж болно:

Командын мөрөөр лог үзэх:

```
-- Бүх аудитын мэдээллийг харах
SELECT * FROM sys.fn_get_audit_file('C:\AuditLogs\*.sqlaudit', DEFAULT, DEFAULT);

-- Тодорхой үйлдлүүдийг шүүж харах
SELECT event_time, action_id, object_name, statement, server_principal_name
FROM sys.fn_get_audit_file('C:\AuditLogs\*.sqlaudit', DEFAULT, DEFAULT)
WHERE action_id IN ('UP', 'DL', 'IN'); -- Update, Delete, Insert үйлдлүүд
```

SSMS-аар лог үзэх:

1. **Object Explorer** дээр **Security** хэсэгт очих
2. **Audits**-ын дор үүсгэсэн аудит дээр хулганы баруун товчийг дараад **View Audit Logs** сонгох
3. Логуудыг огноо, хэрэглэгч, үйлдлээр шүүж харах

БҮЛЭГ 5

Мэдээллийн хамгааллын дүрэм ба нийцэл

Мэдээллийн хамгааллын дүрэм нь байгууллагуудыг хэрэглэгчдийн мэдээллийг хэрхэн хамгаалах, боловсруулах, хадгалах талаарх удирдамжийг өгдөг. Эдгээр дүрэм нь аюулгүй байдлыг сайжруулах, мэдээллийн зөрчил гаргахаас урьдчилан сэргийлэх зорилготой.

GDPR

Европын Нэгдсэн Улсын Ерөнхий Мэдээллийн Хамгааллын Заавар. ЕХ-ны иргэдийн хувийн мэдээллийг хамгаалах өргөн хүрээтэй журам.

CCPA

Калифорнийн Хэрэглэгчийн Мэдээллийн Хамгааллын Хууль. АНУ-ын хэрэглэгчдийн эрхийг хамгаалах журам.

Бусад стандартууд

ISO 27001, SOC 2 зэрэг олон улсын аюулгүй байдлын стандартууд бас чухал үүрэгтэй.

Хэрэглэгчийн мэдээллийг хамгаалах

Нууцлал, бүрэн бүтэн байдал, хэрэглэгчийн мэдээллийг хамгаалахад анхаарах. Мэдээллийн ангилал хийх.

Нийцэх дүрмүүдийг хянах

Мэдээллийн хандалт, өөрчлөлтийг хянах системийг нэвтрүүлэх. Тогтмол аудит хийх.

Хэрэглэгчийн зөвшөөрөл

Хэрэглэгчийн мэдээллийг цуглуулахын өмнө зөвшөөрөл авах. Ил тод байх.

Зөрчлийн төлөв

Хэрэв дүрмийг зөрчвөл ямар арга хэмжээ авах талаар тодорхой байх. Хариу үйлдлийн төлөвлөгөө.

Нийцэл ба олон улсын хууль дүрэм: *Дүгнэлт*

GDPR - General Data Protection Regulation

Европын холбооны иргэдийн хувийн мэдээллийг хамгаалах журам бөгөөд өгөгдлийн санд ямар нэгэн өгөгдөл хадгалахдаа тодорхой стандартыг мөрдөх шаардлагатай.

- Хувийн мэдээллийн эрх
- Өгөгдөл устгах эрх
- Зөвшөөрлийн шаардлага
- Зөрчил мэдэгдэх үүрэг (72 цагийн дотор)
- Их хэмжээний торгууль (20 сая евро эсвэл орлогын 4%)

HIPAA - Health Insurance Portability and Accountability Act

АНУ-ын эрүүл мэндийн байгууллагуудын өгөгдлийн сангийн системүүд нь эмнэлгийн мэдээллийг хамгаалах стандартыг мөрдөх ёстой.

- Эмнэлгийн мэдээллийн нууцлал
- Шифрлэлтийн шаардлага
- Хандалтын хяналт
- Аудитын механизм
- Бизнес түнштэй гэрээ

> ***Дүгнэлт:*** *Эдгээр хуулиуд нь зөвхөн өгөгдлийг хамгаалаад зогсохгүй, тухайн байгууллагыг хуулийн хариуцлагаас хамгаалдаг. Өгөгдлийн сангийн администраторууд эдгээр журмуудыг сайн мэдэж, хэрэгжүүлэх нь чухал үүрэг юм. Нийцэл хангаагүй тохиолдолд их хэмжээний торгууль, хуулийн хариуцлага хүлээх эрсдэлтэй.*